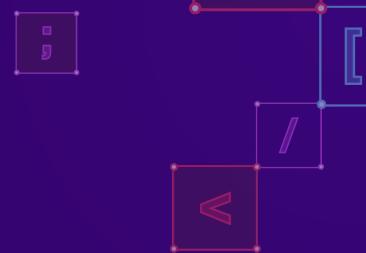


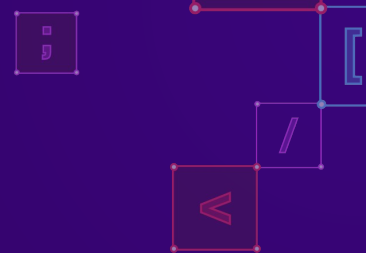
Visual Studio Code is why I have (Workspace) Trust issues

DEF CON 31 - August 11, 2023



Introduction — \$(id)

- We are Paul and Thomas
 - Vulnerability Researchers in the Sonar R&D team
- Sonar helps you write Clean Code
 - Responsible disclosure to fuel our Product Innovation
 - 150+ 0-days over the last two years
 - Pwnie Awards nominations, PortSwigger's Top 10, Pwn2Own, etc.



Introduction — IDEs

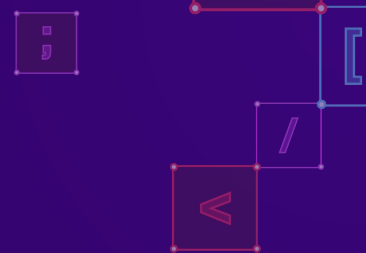
- IDEs are go-to tools for any developer
 - Market share (includes "want to work with", multiple-choices) ^[1]

■ Visual Studio Code	74.09%
■ IntelliJ IDEA	28.06%
■ Notepad++	24.49%
■ Vim	22.59%
■ Nano	8.54%

[1] <https://survey.stackoverflow.co/2023/>

Introduction — Show of hands



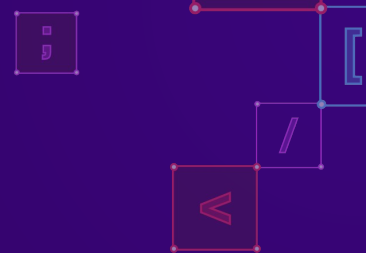


Introduction — IDEs

- The developer tools security status qu^W^W tradeoff
- No "standard" threat model
 - Does it weaken the security of my system?
 - Can I open somebody else's code without any risks?
 - Does my editor run the code? ^[1]
 - Is feature X safe? ^[2]

[1] <https://blog.stmcyber.com/how-to-get-a-heart-attack-while-using-jeb-decompiler/>

[2] <https://github.com/microsoft/vscode-remote-release/issues/6608>

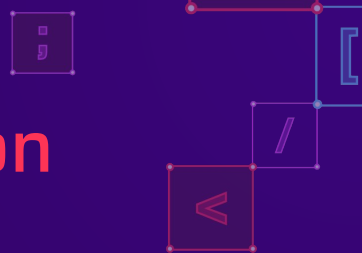


Introduction — IDEs

- Developers are target of choice for threat actors
 - Read/write access to source code, secrets, etc.
 - Access to production
- Documented targeted campaigns against developers
 - Plex 1-day ^[1]
 - Malicious Visual Studio projects ^[2]

[1] <https://arstechnica.com/information-technology/2023/02/lastpass-hackers-infected-employees-home-computer-and-stole-corporate-vault/>

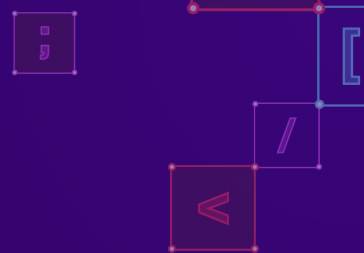
[2] <https://blog.google/threat-analysis-group/new-campaign-targeting-security-researchers/>



Introduction — Structure of the presentation

- IDEs have their own attack surfaces
 - Important to understand how they are architected
 - Focus on the most common sources of risks we saw
 - Core and popular plugins
 - Based on our and other researcher's bugs, credited accordingly
- Reporting process with Microsoft

Visual Studio Code's Architecture



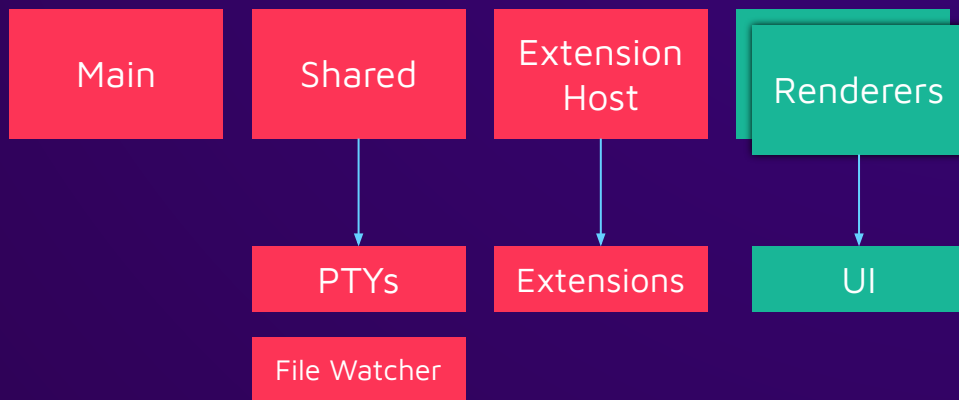
Architecture — Basics

- Based on Electron
 - Also works in the browser! ^{[1][2]}
- Highly extensible
 - Extensions, marketplace
 - Language Server Protocol
- Mostly open-source
 - ~ 800k lines of code
 - OSS and proprietary versions

[1] <https://github.dev> [2] <https://vscode.dev>

Architecture — Components

- Uses Electron's isolation features
 - Uses OS features, e.g. processes
- Privileged
 - Main Process
 - Shared Process
 - Extension Host
- Less privileged
 - Renderer Processes



Architecture — Renderer

Workbench
vscode-file://

Extension
vscode-webview://

```
1 # Visual Studio Code - Open Source ("Code - OSS")
2 [[Feature Requests](https://img.shields.io/github/
  issues/microsoft/vscode/feature-request.svg)]
  (https://github.com/microsoft/vscode/issues?
  q=is%3Aopen+is%3Aissue+label%3Afeature-request
  +sort%3Areactions-%2B1-desc)
3 [[Bugs](https://img.shields.io/github/issues/
  microsoft/vscode/bug.svg)](https://github.com/
  microsoft/vscode/issues?utf8=%E2%9C%93is%3Aissue+is%3Aopen
  +label%3Abug)
4 [[Gitter](https://img.shields.io/badge/
  chat-on%2Bgitter-yellow.svg)](https://gitter.im/
  Microsoft/vscode)

This repository ("Code - OSS") is where we
(Microsoft) develop the [Visual Studio Code](https://
code.visualstudio.com) product together with the
community. Not only do we work on code and issues
here, we also publish our [roadmap](https://github.
com/microsoft/vscode/wiki/Roadmap), [monthly
iteration plans](https://github.com/microsoft/vscode/
wiki/Iteration-Plans), and our [endgame plans]
(https://github.com/microsoft/vscode/wiki/
Running-the-Endgame). This source code is available
to everyone under the standard [MIT license](https://
github.com/microsoft/vscode/blob/main/LICENSE.txt).

## Visual Studio Code

<p align="center">

</p>

[Visual Studio Code](https://code.visualstudio.com)
is a distribution of the "Code - OSS" repository
with Microsoft-specific customizations released
```

Visual Studio Code - Open Source
("Code - OSS")

feature-request issues 2.6k open bug issues 1.8k open chat on gitter

The Repository

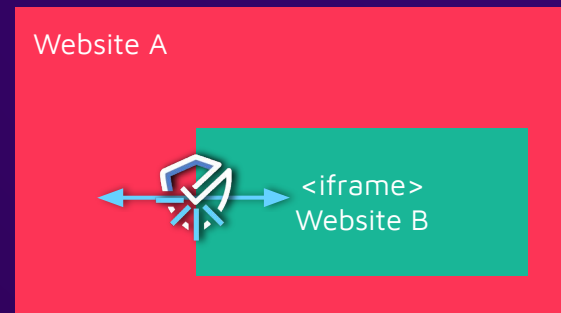
This repository ("Code - OSS") is where we (Microsoft) develop the Visual Studio Code product together with the community. Not only do we work on code and issues here, we also publish our roadmap, monthly iteration plans, and our endgame plans. This source code is available to everyone under the standard MIT license.

Visual Studio Code
vscode-webview://

Visual Studio Code is a distribution of the Code - OSS repository with Microsoft-specific customizations released under a traditional

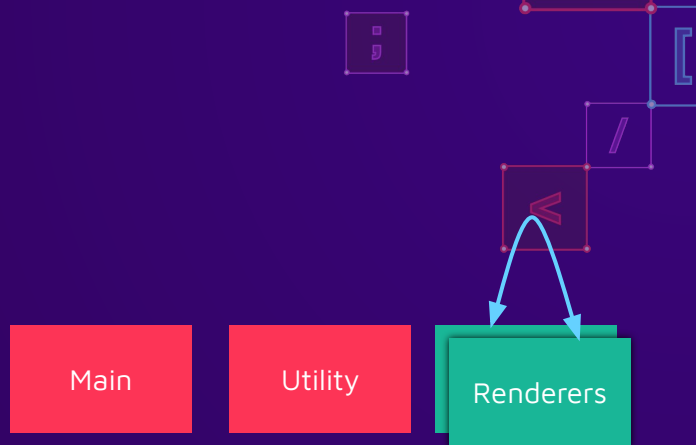
Architecture — Communication

- Same-Origin Policy (SOP)
 - Security boundary in the web
 - Enforces isolation



Architecture — Communication

- Same-Origin Policy (SOP)
 - Security boundary in the web
 - Enforces isolation
- Inter-Process Communication (IPC)
 - Origin to origin: `window.postMessage()`



Architecture — Communication

- Same-Origin Policy (SOP)
 - Security boundary in the web
 - Enforces isolation
- Inter-Process Communication (IPC)
 - Origin to origin: `window.postMessage()`
 - Origin to process: Message Ports



Architecture — Communication

- Same-Origin Policy (SOP)
 - Security boundary in the web
 - Enforces isolation
- Inter-Process Communication (IPC)
 - Origin to origin: `window.postMessage()`
 - Origin to process: Message Ports
 - Renderer to main: preload script and contextBridge



Architecture — Debugging

- **Renderer: DevTools**
 - Ctrl + Shift + I
 - Includes workbench and extension UI
- **Extensions: `code --inspect-extensions`**
 - Including built-ins
- **Debug VS Code with VS Code!**
 - Easy setup ^[1]
 - Many launch configs

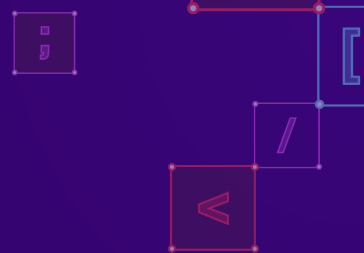


[1] <https://github.com/microsoft/vscode/wiki/How-to-Contribute#debugging>

Exposed Network Services

Exposed Network Services

- Services may start listening on the network
 - Development servers, debuggers, etc.
 - Communication with other components
 - Rarely really required
- Websites and LAN may also reach it
 - Can't only rely on browser mitigations
 - Listening only on `localhost` is not a good solution either



Exposed Network Services — (No CVE?)

- Rainbow Fart (?!), found by Kirill Efimov of Snyk
 - ...128k installs
 - Exposes an HTTP server on port 7777
 - ZIP-based path traversal at `/import-voice-package`
 - Can be triggered with a CSRF from any origin

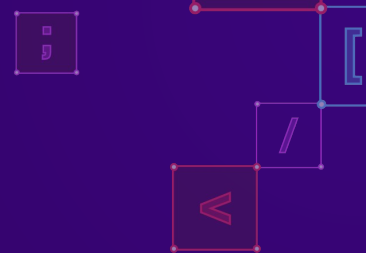
Exposed Network Services — CVE-2019-1414

- Electron spawns a Node.JS inspector with `--inspect=<port>`
 - Reported independently by @phraaaaaaaa and @taviso ^[1] ^[2]
 - In this case, started on localhost and a random port
 - RCE as-a-service with `Runtime.evaluate`
- But, the Same Origin Policy!
 - DNS rebinding
 - WebSockets

[1] <https://iwantmore.pizza/posts/cve-2019-1414.html>

[2] <https://bugs.chromium.org/p/project-zero/issues/detail?id=1944>

Protocol Handlers

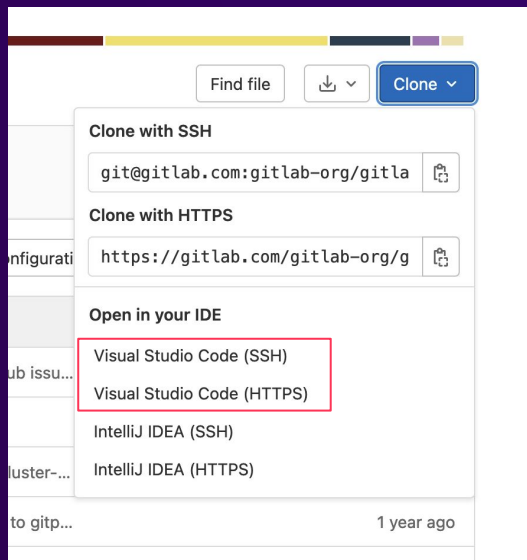


Protocol Handlers — Introduction

- Electron provides a "native" layer
 - Access to the filesystem, network, etc.
 - Better integration in desktop environments
- Applications can register custom protocol handlers
 - `vscode://`
 - `vscode-insiders://`

Protocol Handlers — CVE-2022-30129

- The built-in Git extension allows cloning repositories
 - GitLab uses this functionality for its *Open in your IDE*



Protocol Handlers — CVE-2022-30129

```
export class GitProtocolHandler implements UriHandler {
```

```
  // [...]
```

```
  handleUri(uri: Uri): void {
```

```
    switch (uri.path) {
```

```
      case '/clone': this.clone(uri);
```

```
    private clone(uri: Uri): void {
```

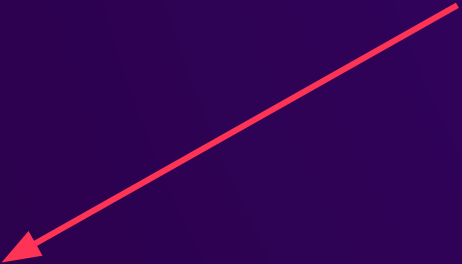
```
      const data = querystring.parse(uri.query);
```

```
      // [...]
```

```
      commands.executeCommand('git.clone', data.url);
```


Protocol Handlers — CVE-2022-30129

```
@command('git.clone')  
async clone(url?: string, parentPath?: string): Promise<void> {  
    await this.cloneRepository(url, parentPath);  
}
```



```
async clone(url: string, options: ICloneOptions, [...]): Promise<string> {  
    // [...]  
    let command = ['clone', url.includes(' ') ? encodeURIComponent(url) : url, folderPath, '--progress'];  
    // [...]  
    await this.exec(options.parentPath, command, { [...]});  
}
```

Protocol Handlers — CVE-2022-30129

- Inject additional arguments to the git invocation

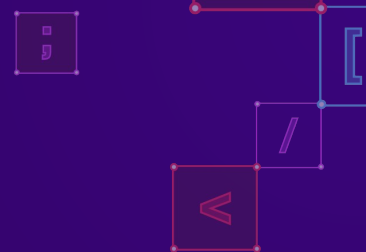
- `git clone '[...]' '/home/user/[...]'`
- `-u <upload-pack>, --upload-pack <upload-pack>`

 Controlled
 Static

- Restrictions

- Colon to trigger the upload-pack
 - Use a command substitution to ignore the suffix
- No space to avoid URL-encoding
 - Use braces expansion

Protocol Handlers — CVE-2022-30129



Protocol

Handler

Upload pack

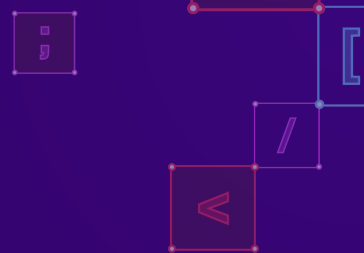
Fake URL

```
vscode://vscode.git/clone?url=-u$({open,-a,calculator}):x
```

git clone '-u\$({open,-a,calculator}):x' '/home/[...]/-u\$({open,-a,calculator}):x'

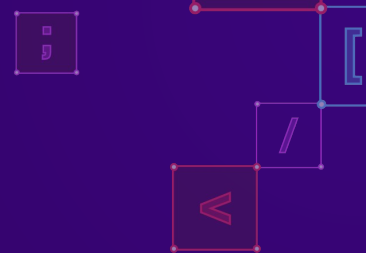
Resulting Invocation

Demonstration



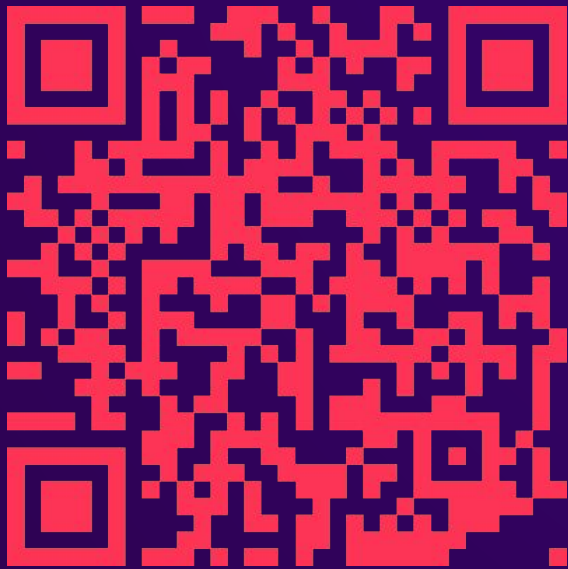
Protocol Handlers — CVE-2020-17148

- Similar finding by @smaury92 ^[1]
 - Remote Development extension, closed-source
 - `vscode://vscode-remote/ssh-remote+<HOST>+<PATH>`
 - Behind the scenes, `ssh -T -D [...] '<HOST>' bash`
 - Sounds familiar?
 - Exploitation with `-OProxyCommand`



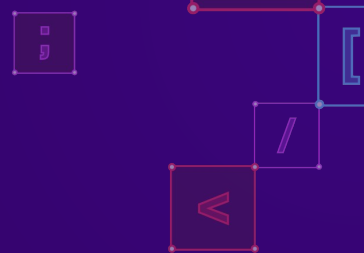
Protocol Handlers — Intermission

- We ❤️ Argument Injection bugs



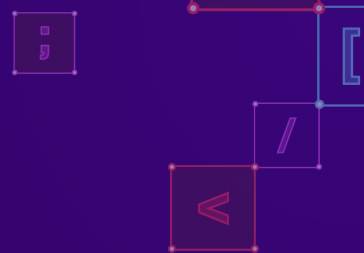
<https://sonarsource.github.io/argument-injection-vectors/>

Workspace Settings and local data



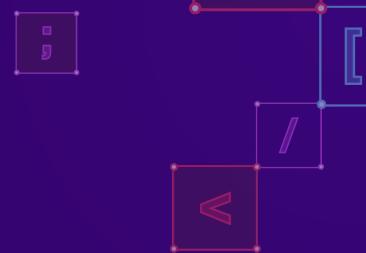
Workspace Settings — Introduction

- VSCode supports per-workspace settings
 - `.vscode/settings.json`
 - Share settings with your project, for other developers
 - Loaded when the folder is open
- Can you override sensitive settings?



Workspace Settings — (No CVE?)

- Discovered by Justin Steven in 2017
- `git.path` comes from the workspace settings
- Several invocations, none must fail
 - `<git.path> --version` from the VSCode install folder
 - `<git.path> rev-parse --show-toplevel` from the project folder
- Set `git.path` to `bash`, plant a script named `rev-parse`



Local Data — CVE-2020-16881

- Found by @ddworken ^[1]
- VSCode extracts information from `package.json`
- `npm` is invoked to pull more information on dependencies
 - On hover of dependency names

```
child_process.exec('npm view --json ' + pack + ' description [...] ' )
```

[1] <https://msrc.microsoft.com/en-US/security-guidance/advisory/CVE-2020-16881>

Local Data — CVE-2020-17023

- Later bypassed by Justin Steven with CVE-2020-17023

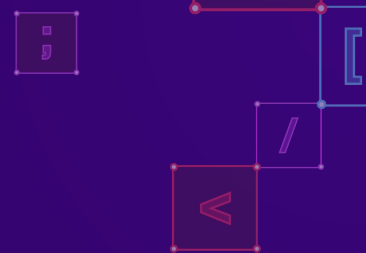
[1]

- Fail-open validation of the dependency name

```
private isValidNPMName(name: string): boolean {  
    // [...]  
    const match = name.match(/^(?:@([^\/*]*)\/)?([^\/*]*)$/);  
    if (match) {  
        const scope = match[1];  
        if (scope && encodeURIComponent(scope) !== scope) {  
            return false;  
        }  
        // [...]  
    }  
    return true;  
}
```

[1] <https://github.com/microsoft/vscode/issues/107951>

Workspace Trust



Workspace Trust — Introduction

- Workspace Trust
 - Introduced in v1.57 (May 2021)
 - Reduces impact of malicious folders
- New security assumptions
 - Untrusted folders are safe to open in restricted mode
 - Trusting a folder is unsafe
 - They're not treated as security bugs anymore?

Workspace Trust — Introduction



Do you trust the authors of the files in this folder?

Code - Insiders provides features that may automatically execute files in this folder.

If you don't trust the authors of these files, we recommend to continue in restricted mode as the files may be malicious. See [our docs](#) to learn more.

/private/var/folders/jd/mppv6tm94vv96bfvn8dyj76r0000gp/T/tmp.IBCKzppv

☐ Trust the authors of all files in the parent folder 'T'

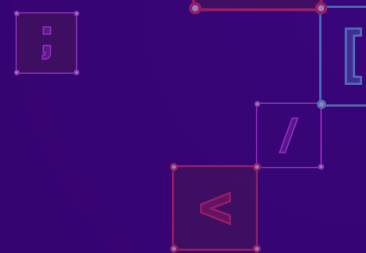
No, I don't trust the authors

Browse folder in restricted mode

Yes, I trust the authors

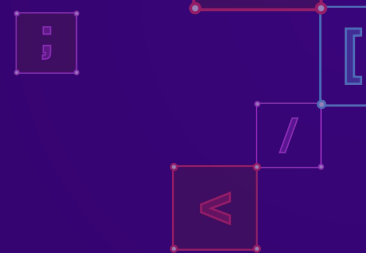
Trust folder and enable all features

Start Debugging **F5**



Workspace Trust — Introduction

- Extensions declare their capabilities in `package.json`
 - Default value is `false`, the safest!
 - Support of `limited`
 - Create a restricted set of Workspace Settings
 - `workspace.onDidGrantWorkspaceTrust`, `workspace.isTrusted`



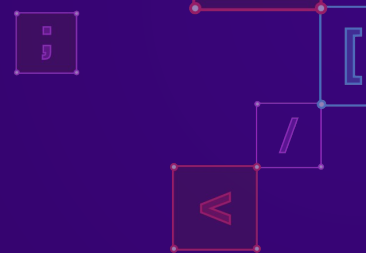
Workspace Trust — CVE-2021-43891

- The Git built-in extension runs in untrusted workspaces

```
"capabilities": {  
  "untrustedWorkspaces": {  
    "supported": true
```

- git supports several levels of configuration ^[1]
 - System (/etc/gitconfig)
 - Global (~/.gitconfig)
 - Local (.git/config)

[1] <https://git-scm.com/docs/git-config>



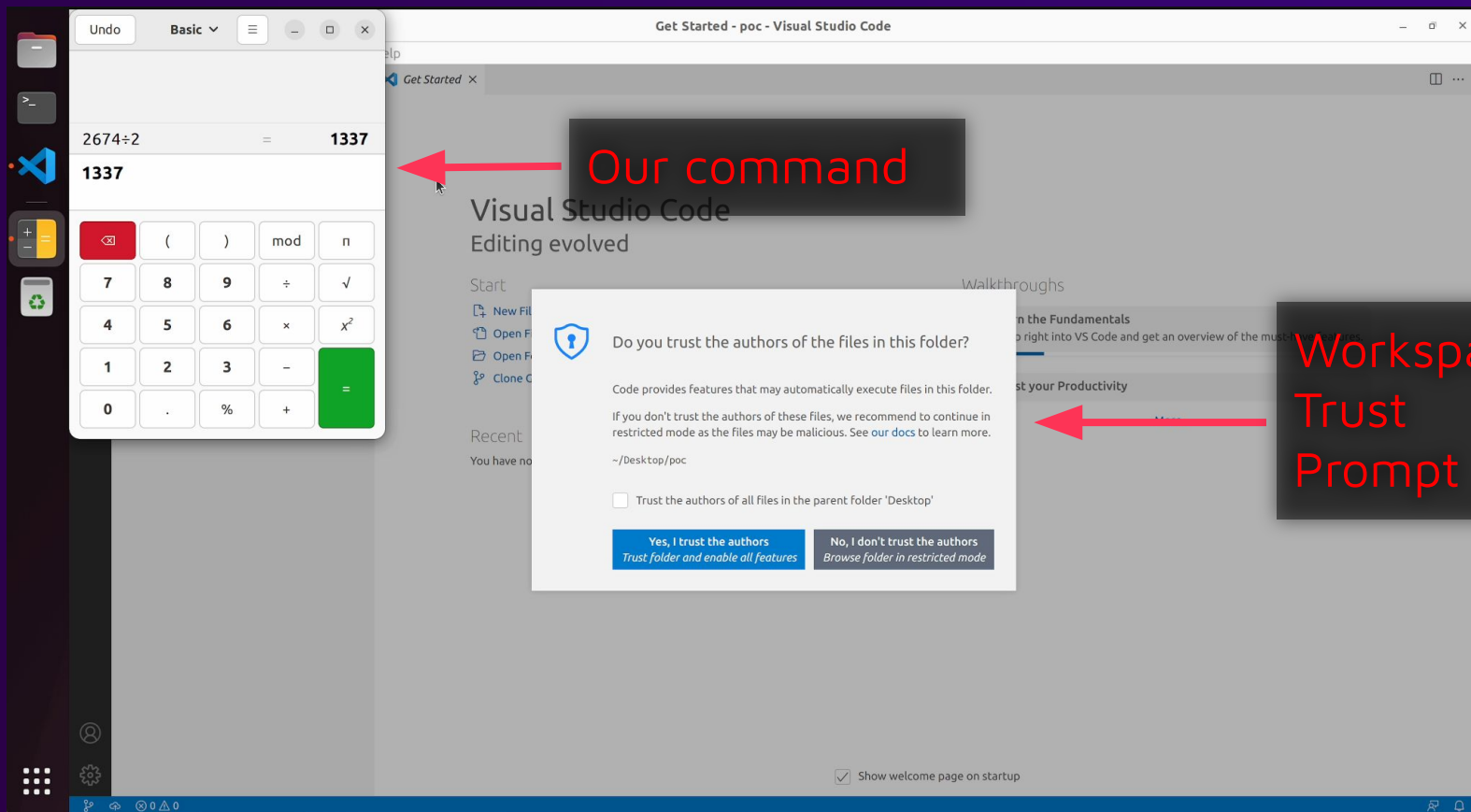
Workspace Trust — CVE-2021-43891

- Cloning does not retrieve local configuration...
 - Archives, or other source code management tools
 - Git Bare repositories in subfolders^[1]
- `core.fsmonitor`
 - *If set, the value of this variable is used as a command which will identify all files that may have changed since the requested date/time.*
- Not specific to Visual Studio Code^{[1] [2]}

[1] https://github.com/justinsteven/advisories/blob/main/2022_git_buried_bare_repos_and_fsmonitor_various_abuses.md

[2] <https://blog.sonarsource.com/securing-developer-tools-git-integrations/>

Demonstration

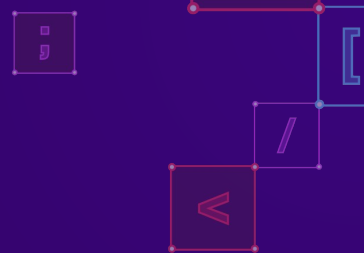


Our command

Workspace
Trust
Prompt

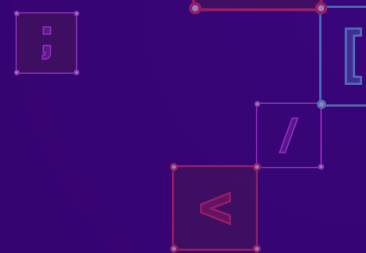
Demonstration (for shell prompts)

Cross-Site Scripting (XSS)



Cross-Site Scripting — Introduction

- Once again, VSCode is powered by a web browser
- XSS bugs in the IDE can be very nasty
 - Parts of the UI need to be privileged
 - Extensions can have webviews



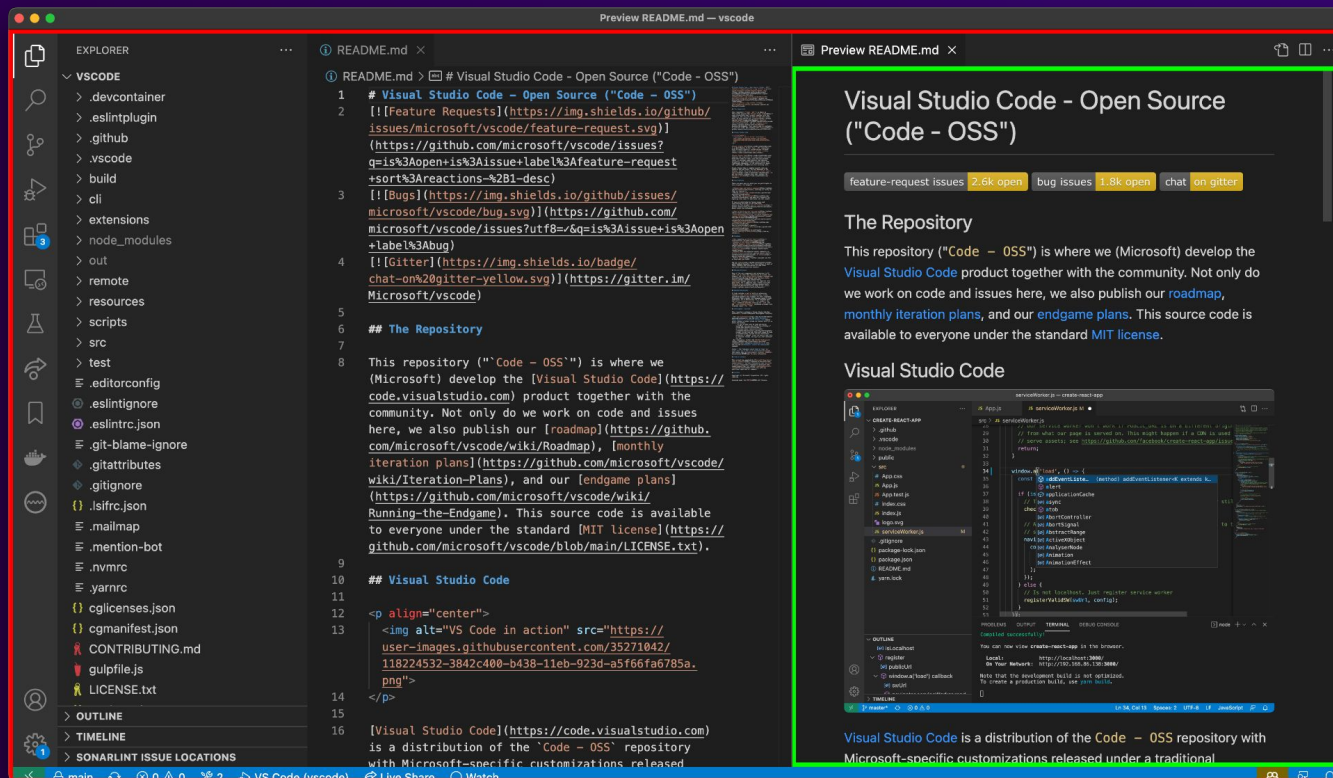
Cross-Site Scripting — CVE-2021-43908

- Cross-Site Scripting in the Markdown preview
 - Research by @TheGrandPew and @s1r1us ^[1] ^[2]
- Control extension webview content
 - Using `<meta>` redirect to navigate away

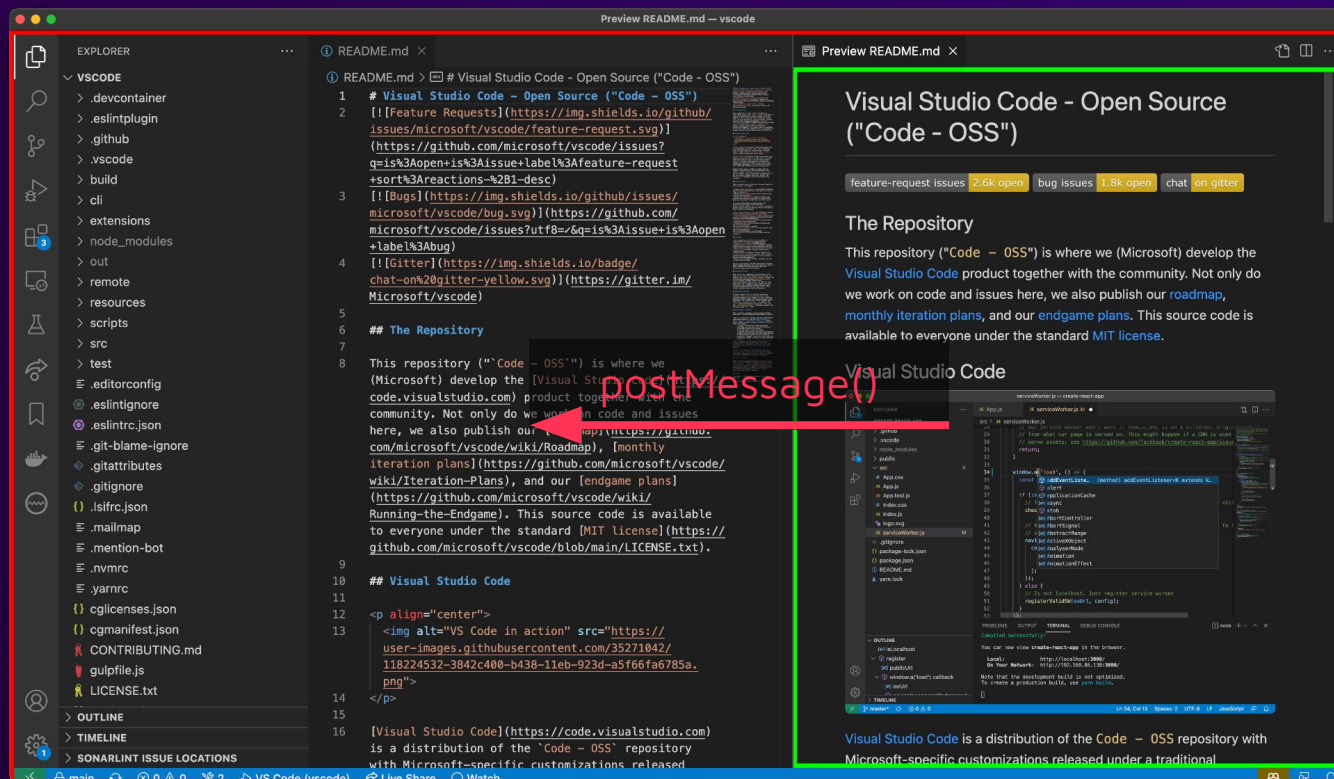
[1] <https://blog.electrovolt.io/posts/vscode-rce/>

[2] <https://www.youtube.com/watch?v=Olq6XnZ4Pwo>

Cross-Site Scripting — CVE-2021-43908



Cross-Site Scripting — CVE-2021-43908



Cross-Site Scripting — CVE-2021-43908

The screenshot shows the Visual Studio Code interface with a README file open. The README content is as follows:

```
1 # Visual Studio Code - Open Source ("Code - OSS")
2 [[Feature Requests](https://img.shields.io/github/
  issues/microsoft/vscode/feature-request.svg)]
  (https://github.com/microsoft/vscode/issues?
  q=is%3Aopen+is%3Aissue+label%3Afeature-request
  +sort%3Areactions-%2B1-desc)
3 [[Bugs](https://img.shields.io/github/issues/
  microsoft/vscode/bug.svg)] (https://github.com/
  microsoft/vscode/issues?utf8=%E2%9C93%3Aissue+is%3Aopen
  +label%3Abug)
4 [[Gitter](https://img.shields.io/badge/
  chat-on%20gitter-yellow.svg)] (https://gitter.im/
  Microsoft/vscode)
5
6 ## The Repository
7
8 This repository ("Code - OSS") is where we
  (Microsoft) develop the [Visual Studio Code]
  (code.visualstudio.com) product together with the
  community. Not only do we work in code and issues
  here, we also publish our [roadmap] (https://github.
  com/microsoft/vscode/wiki/Roadmap), [monthly
  iteration plans] (https://github.com/microsoft/vscode/
  wiki/Iteration-Plans), and our [endgame plans]
  (https://github.com/microsoft/vscode/wiki/
  Running-the-Endgame). This source code is available
  to everyone under the standard [MIT license] (https://
  github.com/microsoft/vscode/blob/main/LICENSE.txt).
9
10 ## Visual Studio Code
11
12 <p align="center">
13   
17 </p>
18
19 [Visual Studio Code] (https://code.visualstudio.com)
  is a distribution of the "Code - OSS" repository with
  Microsoft-specific customizations released
```

The rendered preview shows the README content with the following text:

Visual Studio Code - Open Source ("Code - OSS")

feature-request issues 2.6k open bug issues 1.8k open chat on gitter

The Repository

This repository ("Code - OSS") is where we (Microsoft) develop the Visual Studio Code product together with the community. Not only do we work on code and issues here, we also publish our roadmap, monthly iteration plans, and our endgame plans. This source code is available to everyone under the standard MIT license.

Visual Studio Code

Visual Studio Code is a distribution of the Code - OSS repository with Microsoft-specific customizations released under a traditional



Cross-Site Scripting — Jupyter Notebook XSS

- Jupyter Notebook XSS ^[1]
 - By Justin Steven
 - Render an .ipynb cell as Markdown
 - Read files via
`https://file+.vscode-resource.vscode-webview.net/<path>`
- Refined to RCE (CVE-2021-26437) ^[2]
 - By Luca Carettoni of Doyensec
 - Used `vscode-file://` path traversal and leak

[1] https://github.com/justinsteven/advisories/blob/master/2021_vscode_ipynb_xss_arbitrary_file_read.md

[2] <https://blog.doyensec.com/2022/10/27/jupyttervscode.html>



Cross-Site Scripting — Command Handler RCE

- By @zemnmez of Google ^[1]
- A different .ipynb Markdown trick
- Auto-click `<a href="command:...">` tag with JS
- Use `workbench.action.terminal.new` to open a terminal
- Bypasses isolation, allows direct code execution

[1] <https://github.com/google/security-research/security/advisories/GHSA-pw56-c55x-cm9m>

Markdown Injection

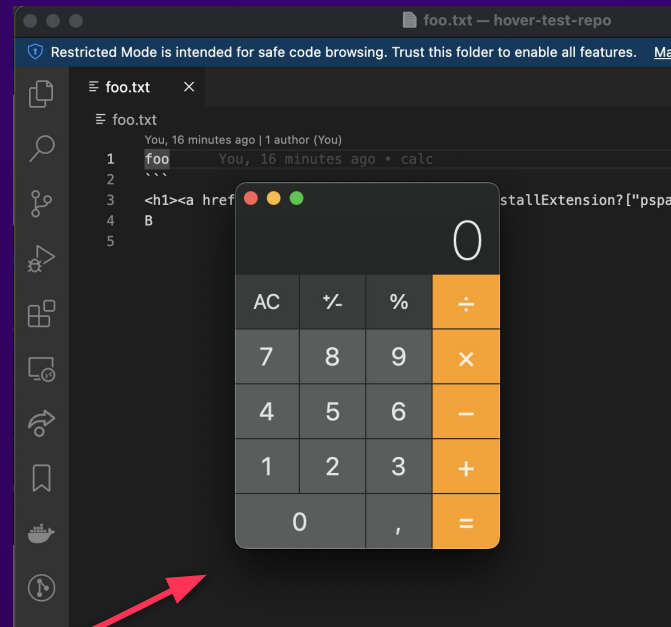
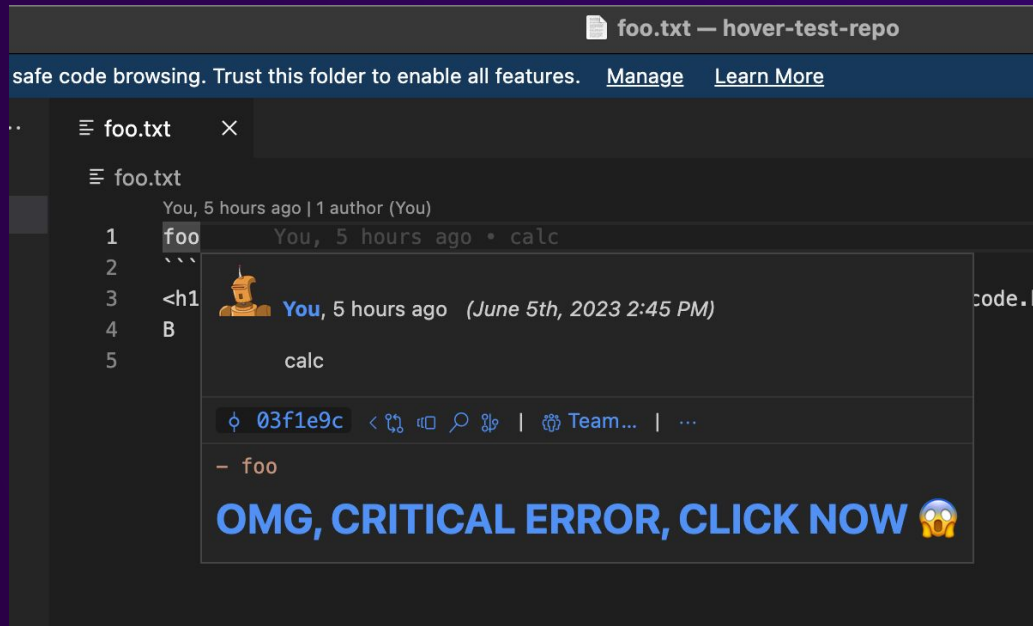
- A **lot** of the UI is Markdown
 - Tooltips, status bar, menus, ...
- Markdown Injection can happen
- Setting `isTrusted = true` allows for `command:` links
 - Run internal commands
 - Requires user interaction

Markdown Injection — GitLens

- GitLens
 - Third-party extension
 - 25 million installs
- Markdown Injection in hover tooltips
- Payload in a commit message
- `command:workbench.extensions.installExtension`
- Fixed in v14.0.0, CVE pending



Markdown Injection — GitLens

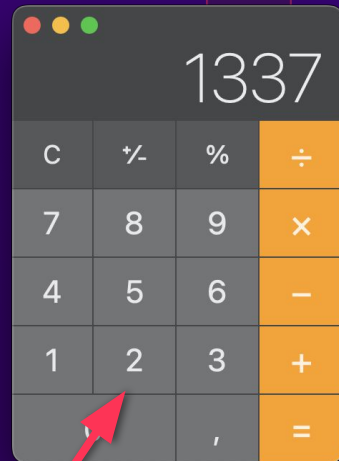
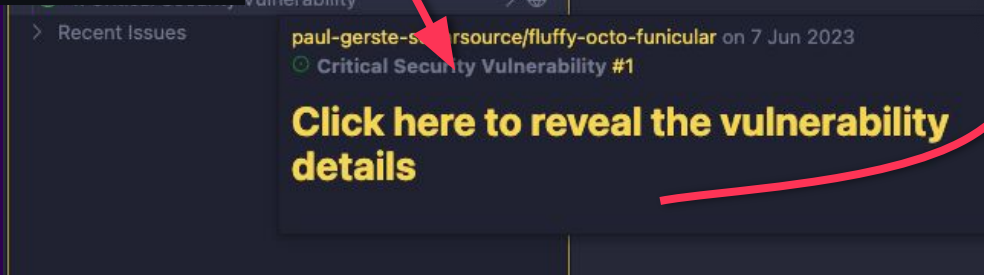
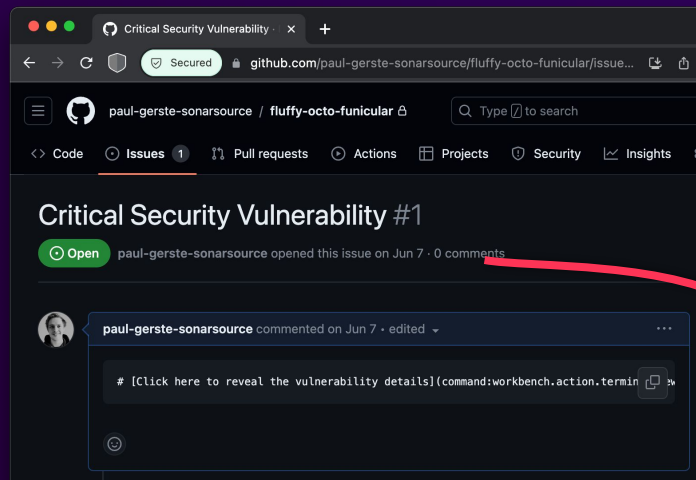


Markdown Injection — GitHub PRs and Issues

- GitHub Pull Requests and Issues
 - Third-party extension by GitHub
 - 13 million installs
- Markdown Injection in hover tooltips (again!)
- Payload in a issue or PR description
- Can be exploited "remotely"
- Fixed in v0.67.2023062909, CVE pending



Markdown Injection — GitHub PRs and Issues



Reporting to Microsoft

Reporting to Microsoft — Process

- We used the official MSRC submission platform
 - <https://msrc.microsoft.com/report/vulnerability>
 - Much better legal terms than bug bounty platforms!
 - Bad reputation because of delays, but good experience so far
 - All steps are centralized in this interface

Reporting to Microsoft — Bounties :)

- CVE-2021-43891: Git local-level configuration
 - \$30,000 USD awarded; donated to 4 charities 🎉

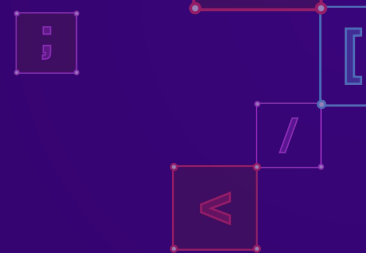
Reporting to Microsoft — Bounties >:(

- CVE-2021-43891: Git local-level configuration
 - \$30,000 USD awarded; donated to 4 charities 🎉
- CVE-2022-30129: Git protocol handler argument injection
 - "**Case X was awarded due to our error.** VS Code extensions, including those built in, were moved out of scope for bug bounty awards August 2020"

Reporting to Microsoft — Bounties

- CVE-2021-43891: Git local-level configuration
 - \$30,000 USD awarded; donated to 4 charities 🎉
- CVE-2022-30129: Git protocol handler argument injection
 - "**Case X was awarded due to our error.** VS Code extensions, including those built in, were moved out of scope for bug bounty awards August 2020"
- MSRC Leaderboard in Q2 2022 and Q2 2023

Conclusion



Conclusion

- CVEs hint at buggy components
 - Justin Steven bypassed many patches
 - Patches are often incomplete
- You click "Trust", you lose
 - Git config exploits still work in trusted workspaces
 - Don't click this button just to get rid of the nag screen

Conclusion

- Attacking desktop applications is also fun!
 - New set of assumptions and surfaces
- Bug bounty scope does not reflect the real threat model
 - Default, built-in modules are excluded?!
- Developer tools are not always built with security in mind
 - Responsibility: user vs. tool
 - We like the principle of least surprise
 - Workspace Trust is a very welcome addition

Thank you!



@Sonar_Research



@SonarResearch@infosec.exchange



<https://sonarsource.com>